

D489

Cybersecurity Management

Armored Drill

8 concepts · 12 items · 4 transfer items

What this is. Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

Source. Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

Target word _____	The one fact that decides _____	Answer _____	[] sure [] unsure [] guess
-----------------------------	---	------------------------	----------------------------------

Items

1.

A dental group with 18 offices learns that a breach of its patient billing system could cost about \$2 million. Its IT director has been with the group for 11 years. Leadership buys a cyber insurance policy that would cover most of that loss. Which risk response is this?

- A. Risk mitigation, because the loss to the group is reduced.
- B. Risk avoidance.
- C. Risk acceptance, because any risk that can still happen is always accepted.
- D. Risk transfer.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

2. [TRANSFER — reversed stem / different variable]

A company judges the risk of a planned mobile payment feature too high and cancels the feature before launch. Which risk response is this?

- A. Risk acceptance.
- B. Risk transfer.
- C. Risk avoidance.
- D. Risk mitigation.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

3.

A distribution center's server room holds equipment valued at \$500,000. A flood would destroy 40% of it, and floods are expected once every 20 years. The building was inspected last spring and has 24-hour guards. What is the annualized loss expectancy (ALE)?

- A. \$10,000
- B. \$200,000
- C. \$4,000,000
- D. \$25,000

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

4. [TRANSFER — reversed stem / different variable]

An asset's ALE is \$30,000 and its SLE is \$120,000. What is the annualized rate of occurrence (ARO)?

- A.** 0.25 (about once every four years)
- B.** 1.0, because a listed risk is assumed to occur every year.
- C.** 0.30
- D.** 4 (four times a year)

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

5.

A proposed monitoring control costs \$15,000 a year. It would lower a system's ALE from \$60,000 to \$20,000. The vendor has been in business since 1998. What is the control's net annual value to the company?

- A.** \$55,000
- B.** \$45,000
- C.** \$40,000
- D.** \$25,000

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

6.

A university's security office, which reports to the provost and has a staff of nine, needs a document that lists the exact steps help desk staff follow to reset a faculty member's password. Which document type is this?

- A.** A policy.
- B.** A procedure.
- C.** A standard.
- D.** A guideline.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

7. [TRANSFER — reversed stem / different variable]

Which type of security document is optional, offering recommended practices rather than required rules?

- A.** A procedure.
- B.** A standard.
- C.** A policy.
- D.** A guideline.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

8.

At a health insurer, the vice president of claims decides who may view claims data and how it is classified. The database administrators, who work in a separate building, run nightly backups and apply the access rules. Who is the data owner?

- A.** The chief information security officer.
- B.** The database administrators.
- C.** The vice president of claims.
- D.** Every employee who uses claims data.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

9. [TRANSFER — reversed stem / different variable]

A data owner assigns daily backups and access setup to the IT team. The data is later found to be misclassified. Who remains accountable?

- A.** The IT team, because it now performs the work.
- B.** The external auditor.
- C.** The data owner.
- D.** No one, since accountability passes with the tasks.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

10.

A private software firm in Ohio with no government contracts and no health or payment card data is choosing between the NIST Cybersecurity Framework and ISO/IEC 27001. Its board meets quarterly. Which statement is accurate?

- A.** Both are voluntary for this firm; it may adopt either to structure its program.
- B.** ISO/IEC 27001 is required by federal law.
- C.** The NIST CSF is mandatory for all U.S. companies.
- D.** It must adopt both once the board votes at its next quarterly meeting.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

11.

After adding MFA and encryption, a retail chain's risk team estimates the remaining yearly loss exposure on its loyalty app at \$8,000, below the \$25,000 the board set as acceptable. The app has 1.2 million members. What should happen next?

- A.** Shut down the app to avoid the risk.
- B.** Management formally accepts the residual risk and keeps monitoring it.
- C.** Keep adding controls until the risk reaches zero.
- D.** Record \$25,000 as the residual risk.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

12.

A startup's risk team rates each risk high, medium, or low for likelihood and impact and plots them on a heat map because it lacks reliable loss data. The team uses a shared spreadsheet built last year. What kind of risk assessment is this?

- A.** A compliance audit.
- B.** Qualitative.
- C.** Quantitative.
- D.** Quantitative, because the ratings are stored in a spreadsheet.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

STOP

Answers and dissection follow. Finish every item and every strip first.

Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

1. Answer D Concept 1

A dental group ~~with 18 offices~~ learns that a breach of its patient billing system could cost about \$2 million. ~~Its IT director has been with the group for 11 years.~~ Leadership buys a cyber insurance policy that would cover most of that loss. Which risk response is this?

Target word: name the risk response **Decides:** Insurance shifts the financial impact to another party.

A	Confusion set	Mitigation lowers the likelihood or impact of the event itself; insurance does not change the breach.
B	Adjacent category	Avoidance means stopping the activity; the billing system keeps running.
C	Absolute language	The breach can still occur, but the chosen response shifts its cost.
D	Correct	Insurance moves the financial consequence to the insurer.

2. Answer C Concept 1 • transfer

A company judges the risk of a planned mobile payment feature too high and cancels the feature before launch. Which risk response is this?

Target word: response when the activity is dropped **Decides:** The activity creating the risk is stopped.

A	Inverted operation	Acceptance keeps the activity and the risk; this does the opposite.
B	Confusion set	No other party takes on the loss.
C	Correct	Cancelling the activity removes the risk.
D	Adjacent category	Mitigation keeps the activity and adds controls.

3. Answer A Concept 2

A distribution center's server room holds equipment valued at \$500,000. A flood would destroy 40% of it, and floods are expected once every 20 years. ~~The building was inspected last spring and has 24-hour guards.~~ What is the annualized loss expectancy (ALE)?

Target word: ALE **Decides:** $SLE = \$500,000 \times 0.40 = \$200,000$; $ARO = 1/20 = 0.05$.

A	Correct	$\$200,000 \times 0.05 = \$10,000$.
B	Dropped element	That is the SLE; it leaves out the yearly rate.
C	Inverted operation	$\$200,000 \times 20$ multiplies by the years between floods instead of the yearly rate.
D	Wrong stem number	$\$500,000 \times 0.05$ uses the full asset value instead of the SLE.

4. Answer A Concept 2 • transfer

An asset's ALE is \$30,000 and its SLE is \$120,000. What is the annualized rate of occurrence (ARO)?

Target word: solve for ARO **Decides:** $ARO = ALE / SLE$.

A	Correct	$\$30,000 / \$120,000 = 0.25$.
B	Absolute language	ARO comes from the figures, not an assumption.
C	Wrong stem number	Reads the ALE's leading digits as a rate.
D	Inverted operation	$\$120,000 / \$30,000$ divides the wrong way.

5. Answer D Concept 3

A proposed monitoring control costs \$15,000 a year. It would lower a system's ALE from \$60,000 to \$20,000. ~~The vendor has been in business since 1998.~~ What is the control's net annual value to the company?

Target word: net annual value **Decides:** Value = reduction in ALE minus control cost.

A	Inverted operation	Adds the control cost instead of subtracting it.
B	Wrong stem number	\$60,000 – \$15,000 ignores the ALE after the control.
C	Dropped element	The ALE reduction without subtracting the control's cost.
D	Correct	$(\$60,000 - \$20,000) - \$15,000 = \$25,000$.

6. Answer B Concept 4

A university's security office, ~~which reports to the provost and has a staff of nine,~~ needs a document that lists the exact steps help desk staff follow to reset a faculty member's password. Which document type is this?

Target word: document type **Decides:** "Exact steps" to follow.

A	Adjacent category	Policies state high-level intent, not keystroke steps.
B	Correct	Procedures give step-by-step instructions.
C	Confusion set	Standards set required specifics such as password length, not the reset steps.
D	Confusion set	Guidelines are optional advice; these steps must be followed.

7. Answer D Concept 4 • transfer

Which type of security document is optional, offering recommended practices rather than required rules?

Target word: find the optional document — reverse **Decides:** Only guidelines are non-mandatory.

A	Adjacent category	Procedures are required steps for a task.
B	Confusion set	Standards are mandatory specifics.
C	Inverted operation	Policies are the top-level mandatory documents, the opposite of optional.
D	Correct	Guidelines recommend; they do not require.

8. Answer C Concept 5

At a health insurer, the vice president of claims decides who may view claims data and how it is classified. The database administrators, ~~who work in a separate building,~~ run nightly backups and apply the access rules. Who is the data owner?

Target word: data owner **Decides:** The VP decides classification and access.

A	Adjacent category	The CISO sets the program and advises, but does not own the claims data.
B	Confusion set	They are custodians: they carry out the owner's decisions.
C	Correct	The owner is the business leader who classifies data and approves access.
D	Absolute language	Users must follow the rules, but ownership sits with one accountable role.

9. Answer C Concept 5 • transfer

A data owner assigns daily backups and access setup to the IT team. The data is later found to be misclassified. Who remains accountable?

Target word: accountability after delegation **Decides:** Tasks can be delegated; accountability cannot.

A	Inverted operation	IT is the custodian; delegation does not move accountability.
B	Adjacent category	Auditors assess controls; they do not own the data.
C	Correct	Classification is the owner's decision, and accountability stays with the owner.
D	Dropped element	Drops the rule that accountability stays with the owner.

10. Answer A Concept 6

A private software firm ~~in Ohio~~ with no government contracts and no health or payment card data is choosing between the NIST Cybersecurity Framework and ISO/IEC 27001. ~~Its board meets quarterly.~~ Which statement is accurate?

Target word: legal status of the frameworks **Decides:** No law, contract, or regulated data requires either framework here.

A	Correct	Frameworks become mandatory only through a law, contract, or customer requirement.
B	Confusion set	ISO 27001 is an international standard, not a law.
C	Absolute language	The CSF is voluntary guidance for private firms.
D	Camouflage	The meeting schedule does not create a legal requirement.

11. Answer B Concept 7

After adding MFA and encryption, a retail chain's risk team estimates the remaining yearly loss exposure on its loyalty app at \$8,000, below the \$25,000 the board set as acceptable. ~~The app has 1.2 million members.~~ What should happen next?

Target word: handling residual risk within appetite **Decides:** \$8,000 residual is under the \$25,000 appetite.

A	Adjacent category	Avoidance is not needed when risk is within appetite.
B	Correct	Residual risk within appetite is accepted and tracked.
C	Absolute language	Zero risk is not achievable or cost-effective.
D	Wrong stem number	\$25,000 is the appetite threshold, not the remaining exposure.

12. Answer B Concept 8

A startup's risk team rates each risk high, medium, or low for likelihood and impact and plots them on a heat map because it lacks reliable loss data. ~~The team uses a shared spreadsheet built last year.~~ What kind of risk assessment is this?

Target word: assessment type **Decides:** Ratings instead of dollar values.

A	Adjacent category	An audit checks conformance to requirements; it does not rate risks.
B	Correct	Ordinal ratings on a heat map are qualitative.
C	Inverted operation	Quantitative needs dollar values and rates such as ALE.
D	Camouflage	The tool does not change the method.

Triage grid

Write each item number in the box it belongs to.

	Right	Wrong
Sure	Owned.	Concept inversion — top priority. A wrong mental model; it survives rewording.
Unsure / guess	Recognition, not mastery. Re-drill with the transfer.	Not learned yet.

Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

Trap	What it does	In this drill	Your misses
Dropped element	Leaves out a required term or step.	3	
Wrong stem number	A figure copied from the prompt that is not the answer.	4	
Adjacent category	The right idea in the wrong bucket.	8	
Inverted operation	Direction flipped: add/subtract, cause/effect, higher/lower.	7	
Absolute language	Always, never, guarantee — where judgment applies.	5	
Confusion set	Every option is real; the test is exact role-matching.	7	
Camouflage	Answers a stem fact that was never the question.	2	

Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

#	Concept	Rule	Trap	Tell
1	Risk treatment options	Risk can be mitigated (reduce it), transferred (shift the financial impact, e.g., insurance), avoided (stop the activity), or accepted (knowingly retain it).	Calling insurance mitigation because it “reduces the loss.”	Insurance, outsourcing a liability, cancelling a project, or signing off on a known gap.
2	Annualized loss expectancy	$SLE = \text{asset value} \times \text{exposure factor}$; $ALE = SLE \times \text{annualized rate of occurrence}$.	Using asset value instead of SLE, or multiplying by years between events instead of the yearly rate.	A dollar value, a percentage lost per event, and “once every N years.”
3	Control cost-benefit	A control's annual value = ALE before – ALE after – annual cost of the control; spend only when the value is positive.	Counting the risk reduction but forgetting to subtract the control's cost.	Two ALE figures and a yearly control cost.
4	Policy document hierarchy	Policies set mandatory high-level intent, standards set mandatory specifics, procedures give step-by-step instructions, and guidelines are optional advice.	Calling any written instructions a “policy,” or treating guidelines as mandatory.	“Exact steps,” “required configuration,” or “recommended practice.”
5	Data ownership roles	The data owner (a business leader) classifies data and approves access and stays accountable; the custodian (usually IT) carries out protection such as backups and access settings.	Naming IT the owner because it runs the systems, or thinking delegation transfers accountability.	Who decides access and classification vs. who runs backups.
6	Laws vs. frameworks	Laws and regulations are mandatory for the organizations they cover; frameworks such as the NIST CSF and ISO/IEC 27001 are voluntary unless a law, contract, or customer requires them.	Believing the NIST CSF or ISO 27001 is legally required for every company.	A private firm choosing a framework, with no regulated data or government contracts.
7	Residual risk and risk appetite	Risk left after controls is residual risk; if it is within the appetite set by leadership, management formally accepts and monitors it.	Trying to drive risk to zero.	A remaining-risk figure next to an acceptable threshold.
8	Qualitative vs. quantitative assessment	Quantitative assessment uses dollar values and rates (ALE); qualitative uses ratings such as high/medium/low on a heat map.	Calling any assessment kept in a spreadsheet “quantitative.”	Ratings or colors instead of dollar figures.

Course scope (public description): Cybersecurity Management prepares learners to develop organizational information security programs and policies that follow recognized standards, comply with all governing laws and regulations, and meet the needs of the company culture and management organization. The course covers how to perform risk management institutionally, how to manage compliance to information security requirements, and

how to delegate compliance, risk, and security functions to specific roles within the organization. It also helps learners apply strategic decision-making as companies adapt to new technologies, processes, and people practices related to processing, managing, and protecting information resources.